

Este é nosso CTF de Hardware Hacking, usando a firmware vulnerável IoTGoat. Vamos testar o seu conhecimento em Hardware Hacking descobrindo alguns artefatos nesta imagem.

### Qual o hash da senha do usuário iotgoatuser?

Verificando o arquivo passwd e shadow:

```
root@IoTGoat:/# cat /etc/shadow
root:$1$J17H1V0G$Wgw2F/C.nLNTC.4pwDa4H1:18145:0:99999:7:::
daemon:*:0:0:99999:7:::
ftp:*:0:0:99999:7:::
network:*:0:0:99999:7:::
nobody:*:0:0:99999:7:::
dnsmasq:x:0:0:99999:7:::
dnsmasq:x:0:0:99999:7:::
iotgoatuser:$1$79bz0K8z$Ii6Q/if83F1QodGmkb4Ah.:18145:0:99999:7:::
root@IoTGoat:/# cat /etc/passwd
root:x:0:0:root:/root:/bin/ash
daemon:*:1:1:daemon:/var:/bin/false
ftp:*:55:55:ftp:/home/ftp:/bin/false
network:*:101:101:network:/var:/bin/false
nobody:*:65534:65534:nobody:/var:/bin/false
dnsmasq:x:453:453:dnsmasq:/var/run/dnsmasq:/bin/false
iotgoatuser:x:1000:1000:/root:/bin/ash
root@IoTGoat:/# _
```

Note que não temos o acesso direto às senhas, elas ficam escondidas com um algoritmo de hashing desconhecido a princípio. Nesses casos, poderíamos tentar quebrar as hashes usando ferramentas como “John” e “hashcat”, mas uma prática bem comum e certa para abordar o brute force de credenciais é utilizar uma wordlist famosa advinda de um episódio histórico no hacking de sistemas embarcados: a Mirai botnet.

```
iotgoatuser:$1$79bz0K8z$Ii6Q/if83F1QodGmkb4Ah.:18145:0:99999:7:::
```

```
(cereal@ DESKTOP-EM0E755)-[~]  
$ john has.txt --wordlist=/home/cereal/mirai.txt  
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"  
Use the "--format=md5crypt-long" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])  
Will run 12 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
Warning: Only 59 candidates left, minimum 288 needed for performance.  
7ujMko0vizxv (?)  
1g 0:00:00:01 DONE (2026-06-06 11:29) 0.8474g/s 50.00p/s 50.00c/s 50.00C/s xc3511..fucker  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

R: FIAP{79bz0K8zli6Q/if83F1QodGmkb4Ah.}